3.5.3 Access-Control-Allow-Origin with an origin value

The Access-Control-Allow-Origin header can also have an actual origin as a value. For example:

```
Access-Control-Allow-Origin: http://localhost:1111
```

This header indicates that only clients from http://localhost:1111 can access the resource. Clients from other origins will be rejected.

Let's modify the example to respond with an origin value rather than a wildcard. This is pretty easy to do; simply replace the `*` value with `http://localhost:1111`, like in the following code snippet.

```
var handleCors = function(req, res, next) {
  res.set('Access-Control-Allow-Origin', 'http://localhost:1111');
  next();
};
```

Restart the server and reload the client at http://localhost:1111/client.html; you should still see the blog posts, with a successful response in the console.

The Access-Control-Allow-Origin header can have only a single origin value. You cannot specify multiple origins in the same header. If your server supports clients from different origins, the Access-Control-Allow-Origin header will have to contain only the origin for the specific client making the request.

Using the origin value is useful when you have a subset of servers, and you only want to allow CORS requests from those servers. For example, a mobile app may host its app on http://mobile.foo.com, but store its private API on http://api.foo.com. In this case a header with `Access-Control-Allow-Origin: http://mobile.foo.com` could be used to limit CORS requests to the http://mobile.foo.com origin only, as shown in figure 3.21.

You've learned of two ways to enable CORS on a server: using a wildcard value, or specifying a specific origin. But what if you want to prevent clients from certain locations from making CORS requests? The next section looks at how to reject CORS requests.

3.5.4 Rejecting CORS requests

So far we've covered what to do if you want to accept a CORS request. But what if you only want to allow CORS requests from certain origins and reject the others? CORS is strict in the sense that the Access-Control-Allow-Origin value must either be `*` or an exact match of the Origin header. Regular expressions or multiple origins aren't allowed; the Access-Control-Allow-Origin can only grant permissions to one origin at a time. If the Access-Control-Allow-Origin isn't `*` or an exact match of the Origin header, the browser rejects the request.

Table 3.5 summarizes the behavior for Origin and Access-Control-Allow-Origin header combinations. Rejecting a CORS request is as simple as:

- Sending an Access-Control-Allow-Origin header that doesn't match the Origin header
- Removing the Access-Control-Allow-Origin header entirely